

GZ: 2023-0.420.407 dated June 29, 2023 (Case Number: DSB-D550.747)

[Note from the editor: Names and companies, legal forms and product designations, addresses (including URLs, IP and email addresses), file numbers (and the like), etc., as well as their initials and abbreviations may have been abbreviated and/or altered for pseudonymization reasons. Obvious spelling, grammar, and punctuation errors have been corrected.]

Criminal Ruling

Accused: Dr. Dieter N***, born on **.**.1960

You have, as the responsible party within the meaning of Art. 4 No. 7 of Regulation (EU) 2016/679 on the protection of natural persons in the processing of personal data, on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation, hereinafter: "GDPR"), OJ No. L 119 of May 4, 2016, p. 1, as amended, committed the following acts and thereby violated the following administrative provisions:

-

In your role as the responsible party, you unlawfully processed special categories of personal data in the territory of Austria at least from September 27, 2022, to October 3, 2022, by publishing health data of Ms. Karina U*** in response to a W***net review. This was done without any exception to the processing prohibition of special categories of personal data according to Art. 9 para. 2 GDPR being applicable.

You have thereby violated the following provisions of the GDPR:

☐

Processing of special categories of personal data according to Art. 9 GDPR

☐

Principle of processing personal data in a lawful manner, in good faith, and in a transparent manner for the data subject according to Art. 5 para. 1 lit. a GDPR ("Lawfulness, processing in good faith, transparency")

☐

Principle of processing personal data for specified, explicit, and legitimate purposes according to Art. 5 para. 1 lit. b GDPR ("Purpose limitation")

☐

Principle of processing personal data that is adequate, relevant, and limited to what is necessary for the purposes of processing according to Art. 5 para. 1 lit. c GDPR ("Data minimization")

Administrative violation(s) according to:

Art. 5 para. 1 lit. a, lit. b, and lit. c as well as Art. 9 para. 1 in conjunction with Art. 83 para. 1 and 5 lit. a GDPR

OJ L 2016/119, p. 1, as amended

Due to this administrative violation, the following penalty is imposed:

[Note from the editor: This ruling has been contested regarding the amount of the penalty at the Federal Administrative Court and is therefore, as of November 2023, not legally binding in this respect.]

Fine of Euro

if this is uncollectible,

substitute imprisonment of

according to

10,000.00 Euro

336 hours

Art. 83 para. 5 lit. a GDPR in conjunction with § 16

Administrative Offenses Act 1991 – VStG

Furthermore, you are to pay according to § 64 of the Administrative Offenses Act 1991 – VStG:

Euro as a contribution to the costs of the criminal proceedings, which is 10% of the fine,

but at least 10 Euro;

Euro as reimbursement of cash expenses for

The total amount payable (fine/costs/cash expenses) therefore amounts to
Euro

Payment deadline:

If no appeal is filed, this ruling is immediately enforceable. In this case, the total amount is to be paid into the account

[here abbreviated]

in the name of the Data Protection Authority within two weeks after the ruling becomes final.

As a reference, please indicate the case number as well as the date of resolution.

1,000.00

11,000.00

If payment is not made within this period, the total amount may be collected. In this case, a flat fee of five euros must be paid. If payment is still not made, the outstanding amount will be enforced, and in the event of its uncollectibility, the corresponding substitute imprisonment will be executed.

Justification:

1. The following relevant facts are established based on the conducted evidentiary proceedings:

1.1. The accused is a specialist in gynecology and obstetrics and operates a public health practice at the address K***platz **4, **** T***.

1.2. Ms. Karina U*** (hereinafter: the affected party) visited the practice of the opposing party on September 21, 2022, due to an acute health complaint. The opposing party diagnosed her with a vaginal infection.

1.3. On September 26, 2022, the affected party wrote the following review on W***net under her real name:

[Note from the editor: The review by Ms. U*** reproduced here as a facsimile (graphic file) cannot be anonymized with reasonable effort and has therefore been removed. It contains the following content (not quoted verbatim): Not recommended as a doctor. He behaved condescendingly towards me, showed no trace of empathy, and did not engage with me as a patient, even when I was desperate and began to cry. He didn't even ask me about the reason for my visit, and I was immediately referred to his assistant. I understand the time pressure due to the number of patients, but a certain degree of empathy and understanding would be desirable. This would not take up any time.]

1.4. The accused publicly responded on September 27, 2022, to the review of the affected party as follows:

[Note from the editor: The response from the accused reproduced here as a facsimile (graphic file) cannot be anonymized with reasonable effort and has therefore been removed. It contains the following content:]

"Hello Karina! I diagnosed your vaginal infection and treated it appropriately right away. You were able to come in the same day and did not have to pay anything. Unfortunately, that is not enough for you, and now you accuse me of a lack of empathy.... I also expect a certain level of cooperation and attention so that I can conduct the necessary medical consultation."

1.5. The diagnosis of the affected party was at least until October 3, 2022, evident from the publicly accessible response of the accused.

1.6. The accused did not disclose his income and asset situation as well as any potential maintenance obligations to the data protection authority despite being requested to do so twice. Therefore, the data protection authority had to make an estimate (see below under penalty assessment).

2. The findings are made based on the following evaluation of evidence:

2.1. In his justification dated June 2, 2023, the accused confirmed that he had authored the response visible in point 1.4. All findings made in points 1.1 to 1.4 were to be regarded as undisputed.

2.2. That the accused published the medical diagnosis of the affected party at least until October 3, 2023, is evident from the complaint initiating the proceedings under case number D124.1332/22, in which the affected party stated that the response of the accused was still publicly accessible as of October 3, 2023. This was neither disputed by the accused in the complaint proceedings nor in the

present administrative penalty proceedings.

2.3. The accused was requested to justify himself by a letter dated May 9, 2023, and by another letter dated June 12, 2023, to disclose his asset situation as well as any potential maintenance obligations to the data protection authority. In his justification dated June 2, 2023, the accused did not address this, and he did not respond to the second letter from the data protection authority dated June 12, 2023.

3. Legally, this results in:

3.1. Regarding the material scope of application of the GDPR and the jurisdiction of the data protection authority

3.1.1. The material scope of application of the GDPR according to Art. 2 GDPR is undoubtedly fulfilled in the present case. The accused did not assert any claim that the GDPR would not apply. The so-called household exemption according to Art. 2 para. 2 lit. c GDPR is not fulfilled.

3.1.2. Art. 83 para. 5 lit. a GDPR stipulates that in the case of violations of the provisions of Art. 5, 6, 7, and 9 GDPR, fines of up to 20,000,000 euros or, in the case of a company, up to 4% of its total worldwide annual turnover of the preceding financial year may be imposed, whichever amount is higher. According to § 22 para. 5 DSG, the jurisdiction for imposing fines

against

natural

and

legal

persons

for

Austria

as

the

national

supervisory authority at the Data Protection Authority.

3.1.3. As a result, the GDPR applies to the specific case, and the Data Protection Authority is both materially and territorially competent for the present administrative fine procedure.

3.2.

On

the

illegality

of

data processing

and

the

violation

of

processing principles

3.2.1. Art. 4 No. 2 GDPR defines the term "processing" as any operation or set of operations performed on personal data, whether or not by automated means, such as the collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction;

3.2.2. Art. 4 No. 7 GDPR defines the term "controller" as the natural or legal person, authority, agency, or other body that alone or jointly with others determines the purposes and means of the processing of personal data.

3.2.3. According to Art. 4 No. 1 GDPR, "personal data" means any information relating to an identified or identifiable natural person ("data subject"). A person is considered identified when the identity of the person can be directly inferred from the information itself. A person is identifiable if the information is not sufficient on its own to identify the person, but identification is possible when the information is combined with other information.

3.2.4. According to Art. 4 No. 15 GDPR, "health data" means personal data related to the physical or

mental health of a natural person, including the provision of health services, from which information about their health status can be derived.

3.2.5. According to Art. 9 para. 1 GDPR, special categories of personal data (formerly "sensitive data") are those data revealing racial and ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, as well as genetic data, biometric data for the unique identification of a natural person, health data, or data concerning a person's sex life or sexual orientation.

3.2.6. It is undisputed that the accused, as the controller, processed personal data of the affected individuals by publishing his response.

3.2.7. There is also no doubt that the information regarding a person's vaginal infection is a health data within the meaning of Art. 4 No. 15 GDPR.

3.2.8. The processing of health data is generally prohibited under Art. 9 para. 1 GDPR unless one of the exceptions listed exhaustively in para. 2 of the same article applies.

3.2.9. Art. 9 para. 2 GDPR establishes exceptions to the processing prohibition of Art. 9 para. 1 GDPR and restricts the permissibility of data processing to specific conditions listed in para. 2 lit. a to j of the same article, which are narrower than those for the processing of "non-sensitive" data in Art. 6 para. 1 GDPR, particularly lacking the permissibility conditions of "processing in the legitimate interests of the controller or a third party" (Art. 6 para. 1 lit. f) and "processing for the performance of a contract" (Art. 6 para. 1 lit. b) (cf. Kastelitz/Hötzendorfer/Tschohl in Knyrim, DatKomm, Art. 9 GDPR, para. 1).

3.2.10. In this case, the disclosure of the health data of the affected individuals could not be justified by any of the conditions listed in Art. 9 para. 2 GDPR. Processing based on the general justification condition of legitimate interests under Art. 6 para. 1 lit. f GDPR is excluded in the case of health data. The argument of the accused in his justification of June 2, 2023, that he aimed to create an accurate overall picture for potential readers, is therefore irrelevant.

3.2.11. As an interim result, it should be noted that the accused has violated Art. 9 and Art. 5 para. 1 lit. a (principle of lawfulness).

3.2.12. According to Art. 5 para. 1 lit. b GDPR, personal data must be collected for specified, explicit, and legitimate purposes and may not be processed in a manner incompatible with those purposes ("purpose limitation").

3.2.13. In the present case, there was neither a concrete, coherent, nor sufficiently close connection between the purpose of data collection and the further processing of the data, nor was it foreseeable for the affected individual in any way that the accused would publish data regarding her medical diagnosis in response to her W***net rating.

3.2.14. The accused has therefore also violated the principle of purpose limitation according to Art. 5 para. 1 lit. b GDPR.

3.2.15. According to Art. 5 para. 1 lit. c GDPR, personal data must be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed.

3.2.16. The purpose of publishing the diagnosis of the affected individual was, according to the accused, to make his replicating post comprehensible and to create a truthful image for readers.

3.2.17. However, this purpose could not have been fulfilled solely by mentioning the medical diagnosis of the affected individual in the comment. The accused could have easily addressed the negative review without referencing the medical diagnosis.

3.2.18. Therefore, the accused also violated the principle of data minimization according to Art. 5 para. 1 lit. c GDPR.

3.4. Regarding the subjective aspect of the offense

3.4.1. From a subjective perspective, it should be noted in the present case that due to the conscious publication of the medical diagnosis of the affected individual, it can be assumed that the accused intentionally carried out the processing in question. Therefore, there is culpability in the form of intent on the subjective side in the sense of Art. 83 para. 2 lit. b GDPR.

4. Regarding the determination of penalties, the following should be noted:

[Note by the editor: This penalty decision has been challenged regarding the amount of the penalty at the Federal Administrative Court and is therefore, as of November 2023, not legally binding in this respect.]

4.1.

According to Art. 83 para. 1 GDPR, the data protection authority must ensure that the imposition of fines for violations according to paragraphs 5 and 6 is effective, proportionate, and deterrent in each individual case. Furthermore, para. 2 of the same article stipulates that when deciding on the imposition of a fine and its amount, the following must be duly considered in each individual case:

- a) The nature, severity, and duration of the violation, taking into account the nature, scope, or purpose of the processing in question, as well as the number of individuals affected by the processing and the extent of the damage suffered by them;
- b) The intentionality or negligence of the violation;
- c) Any measures taken by the controller or processor to mitigate the damage suffered by the affected individuals;
- d) The degree of responsibility of the controller or processor, taking into account the technical and organizational measures they have implemented in accordance with Articles 25 and 32;
- e) Any relevant previous violations by the controller or processor;
- f) The extent of cooperation with the supervisory authority to remedy the violation and mitigate its possible adverse effects;
- g) Categories of personal data affected by the violation;
- h) The manner in which the violation became known to the supervisory authority, in particular whether and to what extent the controller or processor reported the violation;
- i) [...]
- j) [...]
- k) Any other aggravating or mitigating circumstances in the specific case, such as financial benefits obtained directly or indirectly through the violation or losses avoided.

4.2.

The determination of penalties within a statutory penalty framework is a discretionary decision that must be made according to the criteria established by the legislator in § 19 VStG (see VwGH 05.09.2013, 2013/09/0106).

4.3.

According to § 19 para. 1 VStG, the basis for determining the penalty is the significance of the legally protected interest and the intensity of its impairment by the act. Furthermore, according to the purpose of the penalty, the relevant aggravating and mitigating factors, insofar as they do not already determine the penalty, must be weighed against each other. Special consideration must be given to the extent of culpability. Taking into account the nature of administrative criminal law, the provisions of §§ 32 to 35 of the Criminal Code shall apply *mutatis mutandis*. The income and asset situation and any maintenance obligations of the accused shall be taken into account when determining fines; however, this only to the extent that the directly applicable provisions of the GDPR do not displace the provisions of the VStG and to the extent that is ordered by Art. 83 para. 8 GDPR and Recital 148 regarding the procedural guarantees to be ensured.

4.4.

If a fine is imposed on a natural person, a substitute imprisonment must also be set according to § 16 para. 1 VStG for the case of non-collectibility. The substitute imprisonment must not exceed the maximum of the imprisonment threatened for the administrative offense and, if no imprisonment is threatened and nothing else is specified, two weeks.

4.5. According to the case law of the Administrative Court (VwGH), the authority must proceed with an assessment of the income and asset situation when the accused refuses to provide information about these circumstances during the administrative penalty proceedings (see e.g. VwGH 30.06.2004, 2001/09/0120; 22.04.1992, 92/03/0019; 21.06.1999, 98/17/0009). In this case, the accused must be held responsible for their lack of cooperation if the authority has disregarded circumstances in its assessment that could not have come to the authority's attention without their cooperation.

4.6. In the present case, the income and asset situation of the accused could not be established due to the lack of information provided by the accused and therefore could not be taken into account. The Data Protection Authority was therefore required to make an official estimate as a basis for

determining the penalty.

4.7. According to the general income report of the Court of Auditors, specialist doctors in self-employed work earned an average of EUR 153,399 in 2022 (see <https://www.statistik.at/fileadmin/publications/Einkommensbericht-2022.pdf>, p. 183).

4.8. Based on this, a monthly gross income of the accused in the amount of € 12,800 is assumed in the present case.

4.9. Regarding the present facts, the following aggravating factors were considered in the determination of the penalty:

- Nature and severity of the violation: The processing in question by the accused constitutes a serious infringement of the data protection rights of the affected individual. The affected individual could trust that their health data, in the form of a medical diagnosis, would not subsequently be published on the internet by the accused. As a result, the nature and intensity of the infringement of the fundamental right are classified as high.
- Intentionality: The violation was committed intentionally by the accused (see point 3.5.).

4.10. Mitigating factors considered in the determination of the penalty include:

- Previous convictions: There were no relevant previous convictions against the accused with the Data Protection Authority due to violations of the GDPR or the DSG to date.
- Cooperation in the administrative penalty proceedings: The accused responded in a timely manner to the request for justification in the administrative penalty proceedings. The accused admitted to the Data Protection Authority that they had published the response containing the health data of the affected individual. This contributed to clarifying the facts of the case.

4.11. In determining the penalty, considerations of special prevention and general prevention may also be taken into account according to the consistent case law of the VwGH (see VwGH 15.5.1990, 89/02/0093; VwGH 22.4.1997, 96/04/0253; VwGH 29.1.1991, 89/04/0061). Supervisory authorities must also ensure, according to Art. 83 para. 1 GDPR, that fines are effective, proportionate, and deterrent in each individual case.

4.12. The imposition is necessary in the sense of general prevention to raise awareness among responsible parties (e.g., other responsible parties in the healthcare sector) regarding such unlawful data processing.

4.13. For the amount of the imposed fine, there are also special preventive reasons in the present case. The Data Protection Authority was given the impression that the accused could commit such violations in the future as well. In their justification, they stated that they had been forced to present the background to create an accurate picture. Furthermore, from additional responses of the accused to W***net reviews regarding medical visits that took place with them, it emerges that the accused continuously mentions details of the examinations they conducted in response to negative reviews. Corresponding screenshots can be found in the case file of the Data Protection Authority. Future publications of medical diagnoses by the accused do not seem unlikely at this time.

4.14. The specifically imposed penalty therefore appears to be appropriate in terms of the established income situation of the accused, considering the realized value of the offense measured against the available penalty range of Art. 83 para. 5 GDPR of up to € 20,000,000, and its imposition is necessary to deter the accused and third parties from committing the same or similar punishable acts.